

网络安全

概述

信息保障阶段

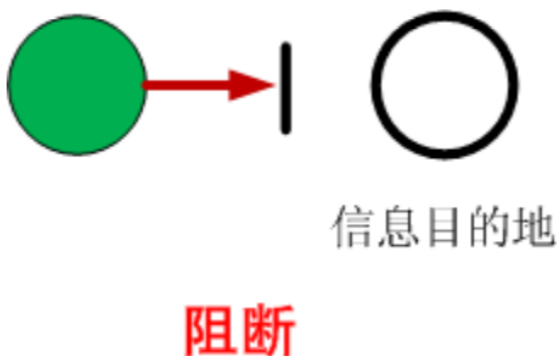
- 信息保障技术框架IATF：由美国国家安全局制定，提出“纵深防御策略”(DiD, Defense-in-Depth Strategy)。
- PDRR模型：保护 (Protection)、检测 (Detection)、响应 (Reaction) 和恢复 (Restore) 的有机结合。



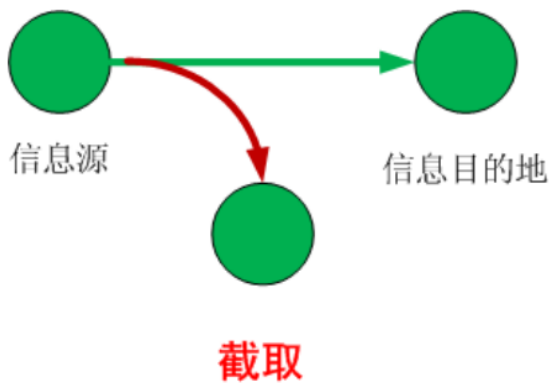
- 信息保障阶段不仅包含安全防护的概念，更重要的是增加了主动和积极的防御观念。

攻击类型（安全属性分类）

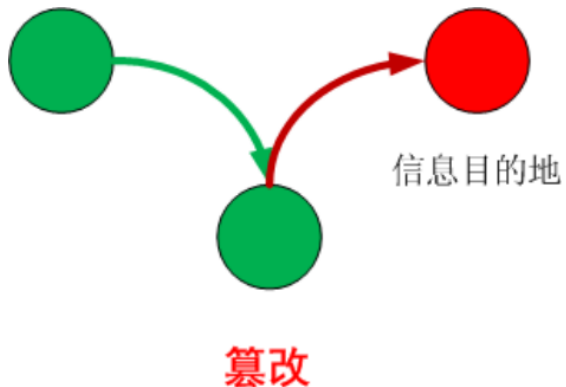
- 阻断攻击：使系统的资产被破坏，无法提供用户使用。→ 可用性



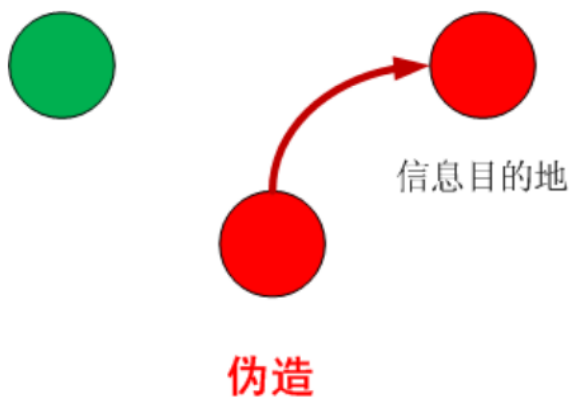
- 截取攻击：可使非授权者得到资产的访问。→ 机密性



- 篡改攻击：非授权者不仅访问资产，而且能修改信息。→ 完整性



- 伪造攻击：非授权者在系统中插入伪造的信息。→ 真实性



网络信息安全服务

- 机密性服务：提供信息的保密。
- 完整性服务：提供信息的正确性
- 可用性服务：提供的信息是可用的。
- 可审性服务：本身不针对攻击提供保护，需与其它服务结合。

网络攻击

ARP攻击

- ARP协议：地址解析协议，根据IP地址获取物理地址的一个TCP/IP协议。
- ARP欺骗：

- 利用修改主机ARP缓存表的方法达到嗅探的目的，是一种中间人攻击。
- 过程：主机C为了达到嗅探的目的，会向主机A和主机B分别发送ARP应答包，告诉它们IP地址为IPB的主机MAC地址为MACC，IP地址为IPA的主机MAC地址为MACC。这样，主机A和主机B的ARP缓存中就会有IPB—MACC和IPA—MACC的记录。这样，主机A和主机B的通信数据都流向了主机C，主机C只要再发送到其真正的目的地就可以了。
- ARP缓存表项是动态更新的（一般为两分钟），如果没有更新信息，ARP映射项会自动删除。所以，主机C在监听过程中，还要不断地向主机A和主机B发送伪造的ARP应答包。

DNS安全

- 查询方式：
 - 递归查询：一般客户机和服务器之间是递归查询，DNS服务器如果未能在本地找到相应的信息，就代替用户向其它服务器进行查询，这时它是代替用户扮演了解析器（resolver）的角色，直到最后把结果找到，也可能根本没有结果，那就返回错误，并返回给用户为止。
 - 迭代（反复）查询：一般服务器之间属于反复查询。DNS服务器返回的要么是本地存在的结果信息，要么是一个错误码，告诉查询者你要的信息这里没有，然后再返回一个可能会有查询结果的DNS服务器地址，让查询者到那里去查一查。
- DNS应答包被客户端接受需要满足以下五个条件：
 - 应答包question域和请求包question域的域名信息一致。
 - 应答包的Transaction ID和请求包中的Transaction ID一致。
 - 应答包的源IP地址与请求包的源IP地址一致。
 - 应答包的源IP地址和端口与请求包的源IP地址和端口一致。
 - 第一个到达的符合以上四个条件的应答包。
- 安全威胁：
 - DNS欺骗攻击：黑客监听客户机DNS查询请求，在遇到后立刻发送一个假答案（内容为映射到黑客可控的恶意IP），显然假答案到的更快，所以后续的真答案会被丢弃，从而成功欺骗。
 - DNS下毒攻击：流程同欺骗，但是监听的是DNS服务器，从而篡改服务器中的映射表内容。

恶意代码

- 木马：病毒、蠕虫和木马的比较

特性	病毒	蠕虫	木马
传染性	强	很弱	很弱
传播能力	强	极强	一般
感染对象	文件	进程	进程

特性	病毒	蠕虫	木马
主要传播方式	文件	网络	网络
破坏性	强	强	很弱
隐蔽性	强	强	极强
顽固性	较强	较强	极强
欺骗性	一般	一般	强
主要攻击目的	破坏数据和信息	耗尽计算机资源	窃取信息、提供后门

- 代码注入：利用 `CreateRemoteThread()` 函数注入
 - 函数声明：

```
HANDLE CreateRemoteThread(
    HANDLE hProcess, // 目标进程的句柄
    LPSECURITY_ATTRIBUTES lpThreadAttributes,
    SIZE_T dwStackSize,
    LPTHREAD_START_ROUTINE lpStartAddress,
    LPVOID lpParameter,
    DWORD dwCreationFlags,
    LPDWORD lpThreadId
);
```

- 远线程注入DLL流程：
 1. 提升自身进程的权限为SeDebugPrivilege（如果不注入系统进程，此步骤可省略）
 2. `OpenProcess()` 获取目标进程的句柄
 3. `VirtualAllocEx()` 在目标进程中分配一块内存
 4. `WriteProcessMemory()` 要注入的DLL路径写入步骤3分配的内存
 5. `GetProcAddress()` 获得 `LoadLibraryA()` 函数的地址
 6. `CreateRemoteThread()` 创建远程线程，线程起始地址设为 `LoadLibraryA()` 函数的地址，线程的参数为步骤4中DLL路径在目标进程中的地址
 7. 等待远程线程结束后退出。

DoS攻击

- Ping of Death：
 - 介绍：一种针对计算机系统的攻击方式，它通过向目标计算机发送畸形或恶意的Ping数据包来实施。
 - 原理：早期的操作系统处理ICMP分组时，只开辟64KB缓冲区用来存放收到的数据包。
 - 攻击：攻击者故意在ICMP Echo数据包(Ping包)之后附加非常多的冗余信息，使数据包的尺寸超过65535个字节的上限。接收方对这种数据包进行处理时就会出现内存分配错误，导致TCP/IP堆栈溢出，从而引起系统崩溃，挂起或重启。
- Teardrop：

- 介绍：一种利用 IP 分片重组漏洞的攻击方式。攻击者向目标机器发送一系列损坏的 IP 分片，这些分片的载荷相互重叠且大小异常。
- 原理：MTU（maximum transfer unit，最大传送单位）限制传输数据的包大小，大数据包需要分段。Teardrop攻击就是利用这种分割重组间的漏洞而产生的攻击方式。Teardrop攻击是向目标机器发送损坏的IP包，诸如重叠的包或过大的包载荷，该攻击通过TCP/IP协议栈中分片重组代码中的bug来瘫痪各种不同的操作系统。
- 攻击：使接收数据方重组数据包时，出现数据包长度超大（如负值），导致溢出。（假设数据包中第二片IP包的偏移量小于第一片结束的位移，而且算上第二片IP包的Data，也未超过第一片的尾部，这就是重叠现象。）
- 实例：计算第二段数据段的空间大小，结果为负数，且 `memset` 函数的参数为无符号整数，导致复制大量的值到一个很小的缓冲区中导致崩溃。

第一片:Fragment offset=0; 数据包长度 (length)=ip.total-length-ip.headerlength=36。

IP 首部(20 字节)	UDP 首部(8 字节)	数据 1(28 字节)
--------------	--------------	-------------

第二片:Fragmentoffset=32; 数据包长度 (length)=ip.total-length-ip.headerlength=3。

IP 首部(20 字节)	数据 2
--------------	------

若两片重组,则第二片必然嵌于第一片内,

1	8 9	32	35 36
IP 首部(20 字节)	UDP 首部(8 字节)	数据 1	数据 2

这时第一片的 end=36,offset=0;第二片的 end=32+3=35,而正常情况下第二片的段偏移 offset=36, 这样造成 `fp->len=end-offset=35-36=-1`。此时调用 `memcpy ((ptr + fp->offset), fp->ptr, fp->len)`时,由于 `fp->len` 为负数,会引起堆栈溢出。

- Land攻击：
 - 介绍：利用特殊的TCP封包传送至目标主机，使其因无法判别而当机或被迫重新启动。
 - 原理：用一个特别打造的SYN包，它的源地址和目标地址都被设置成某一个服务器地址。此举将导致接受服务器向它自己的地址发送SYN—ACK消息，结果这个地址又发回ACK消息并创建一个空连接。被攻击的服务器每接收一个这样的连接都将保留，直到超时。（本质上是一个IP:port只能处理C和S中的一种角色任务，此时让它同时处理两种任务就会造成资源耗尽）
- SYN洪水：
 - 原理：每个机器都需要为半开连接分配一定的资源，这种半开连接的数量是有限制的，攻击方利用TCP连接三次握手过程，打开大量的半开TCP连接，导致目标机器不能进一步接受TCP连接。机器就不再接受进来的连接请求。（不返回ACK包确认连接）
 - 攻击细节：
 - 连接请求是正常的，但是，源IP地址往往是伪造的，并且是一台不可达的机器的IP地址，否则，被伪造地址的机器会重置这些半开连接

- 一般，半开连接超时之后，会自动被清除，所以，攻击者的系统发出SYN包的速度要比目标机器清除半开连接的速度要快
- 任何连接到Internet上并提供基于TCP的网络服务，都有可能成为攻击的目标
- 很难跟踪，因为源地址往往不可信，而且不在线
- Smurf:
 - 原理：攻击者向一个广播地址发送ICMP Echo请求，并且用受害者的IP地址作为源地址，广播地址网络上的每台机器响应这些Echo请求，同时向受害者主机发送ICMP Echo-Reply应答受害者主机被这些大量的应答包淹没
- HTTP洪水（以HTTP GET FLOOD为例）
 - 效果：占用大量HTTP进程导致系统资源耗尽崩溃。
 - 攻击：HTTP GET FLOOD是针对应用服务器上的某个文件，对其进行快速的反复的重复读取操作，从而造成服务器的资源减少直至崩溃。针对的不仅仅是WEB服务器，还有数据库服务器。大量的HTTP请求产生了大量的数据库查询，可以在几秒之内使数据库停止响应，系统负载升高，最终导致服务器宕机。

WEB安全

- XSS:
 - 介绍跨站脚本攻击是指通过存在安全漏洞的Web网站注册用户的浏览器内运行非法的HTML标签或JavaScript进行的一种攻击。
 - 影响：
 - 利用虚假输入表单骗取用户个人信息
 - 利用脚本窃取用户的Cookie值，被害者在不知情的情况下，帮助攻击者发送恶意请求
 - 显示伪造的文章或图片
 - 原理：恶意攻击者往 Web 页面里插入恶意可执行网页脚本代码，当用户浏览该页之时，嵌入其中 Web 里面的脚本代码会被执行，从而达到攻击者盗取用户信息或其他侵犯用户安全隐私的目的。
 - 分类：
 - 反射型：
 - 概念：发生请求时，XSS代码出现在请求URL中，作为参数提交到服务器，服务器解析并响应。响应结果中包含XSS代码，最后浏览器解析并执行
 - 特征：
 - 即时性：不经过服务器存储，直接通过HTTP 的 GET 和POST 请求就能完成一次攻击，拿到用户隐私数据。
 - 攻击者需要诱骗点击
 - 反馈率低，所以较难发现和响应修复
 - 持久型（存储型）：
 - 概念：一般存在于Form表单提交等交互功能，如发帖留言，提交文本信息等，黑客利用的XSS 漏洞，将内容经正常功能提交进入数据库持久保存，当前端页面获得后端从数据库中读出的注入代码时，恰好将其渲染执行。

- 特征：
 - 注入页面方式不是来源于URL，referer，forms 等，而是来源于后端从数据库中读出来的数据
 - 不需要诱骗点击。
 - 持久性，植入在数据库中
 - 危害面广，甚至可以让用户机器变成DDoS 攻击的肉鸡
 - 盗取用户敏感私密信息
- 条件：没转义
 - POST 请求提交表单后端没做转义直接入库；
 - 后端从数据库中取出数据没做转义直接输出给前端；
 - 前端拿到后端数据没做转义直接渲染成DOM
- **基于字符集的XSS**：浏览器以及各种开源的库都专门针对了 XSS 进行转义处理，尽量默认抵御绝大多数 XSS 攻击，但是还是有很多方式可以绕过转义规则，让人防不胜防。比如「基于字符集的 XSS 攻击」就是绕过这些转义处理的一种攻击方式，比如有些 Web 页面字符集不固定，用户输入非期望字符集的字符，有时会绕过转义过滤规则。
- **未经验证的跳转XSS**：有一些场景是后端需要对一个传进来的待跳转的 URL 参数进行一个 302 跳转，可能其中会带有一些用户的敏感（cookie）信息。如果服务器端做302跳转，跳转的地址来自用户的输入，攻击者可以输入一个恶意的跳转地址来执行脚本。（e.g. JavaScript伪协议）
- **CSRF**：
 - 跨站请求伪造攻击，一种常见的Web攻击，利用用户已登录的身份，在用户毫不知情的情况下，以用户的名义完成非法操作。
 - 条件：
 - 用户已经登录了站点A，并在本地记录了cookie
 - 在用户没有登出站点A的情况下（也就是cookie 生效的情况下），访问了恶意攻击者提供的引诱危险站点B（B要求访问A）
 - 站点A未做对CSRF的防御
 - 对比XSS：
 - XSS利用用户对网站的信任，目标代码在用户浏览器中执行，payload一般是js 代码
 - CSRF通过伪造来自受信任用户的请求来利用网站对用户的信任，payload是一个精心构造的HTTP请求
 - 防御（服务端进行）：
 1. 正确使用GET、POST和cookie
 - GET 请求常用在查看，列举，展示等不需要改变资源属性的时候（数据库 query查询的时候）
 - POST 请求常用在 Form 表单提交，改变一个资源的属性或者做其他一些事情的时候（数据库有 insert、update、delete 的时候）
 2. 在非 GET 请求中增加 token

- 为每个用户生成一个唯一的 cookie token，所有表单都包含同一个伪随机值，但是由于用户的 cookie 很容易由于网站的 XSS 漏洞而被盗取，所以这个方案必须要在没有 XSS 的情况下才安全。
- 每个 POST 请求使用验证码，这个方案算是比较完美的，但是需要用户多次输入验证码，用户体验比较差，所以不适合在业务中大量运用。
- 渲染表单的时候，为每一个表单包含一个 csrfToken，提交表单的时候，带上 csrfToken，然后在后端做 csrfToken 验证。
- **SQL注入：**
 - 1998年《Phrack》上发布的 "NT Web Technology Vulnerabilities" 第一次让SQL注入为公众所知。
 - 概念：通过把SQL命令插入到Web表单递交或输入域名或页面请求的查询字符串，最终达到欺骗服务器执行恶意的SQL命令。
 - 核心：命令拼接。
 - 基本流程：寻找注入点 → 信息采集 → 权限判断 → 攻击系统

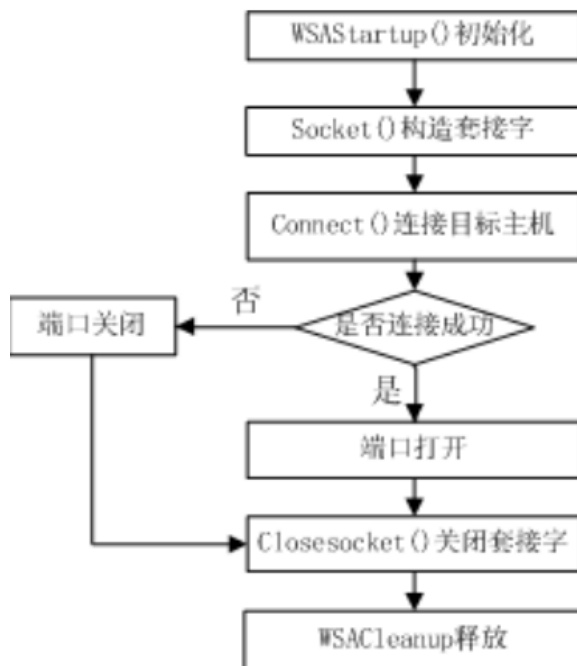
网络扫描：端口扫描技术

- 介绍：端口扫描技术是一项自动探测本地和远程系统端口开放情况的策略及方法，它使系统用户了解系统目前向外界提供了哪些服务，从而为系统用户管理网络提供了一种手段。
- 原理：向目标主机的TCP/IP服务端口发送探测数据包，并记录目标主机的响应，通过分析响应来判断服务端口是打开还是关闭，即可得知端口提供的服务或信息。也可以通过捕获本地主机或服务器流入流出IP数据包来监视本地主机的运行情况，通过对接收到的数据进行分析，帮助我们发现目标主机的某些内在的弱点。
- 分类：全连接扫描、半连接扫描、秘密扫描

全连接扫描（基础）

- **TCP connect()扫描：**
 - 介绍：利用操作系统提供的 connect() 系统调用，与每一个感兴趣的目标计算机的端口进行连接。如果端口处于侦听状态，那么 connect() 就能成功；否则，该端口是不能用的，即没有提供服务。

- 流程：利用基础TCP连接流程

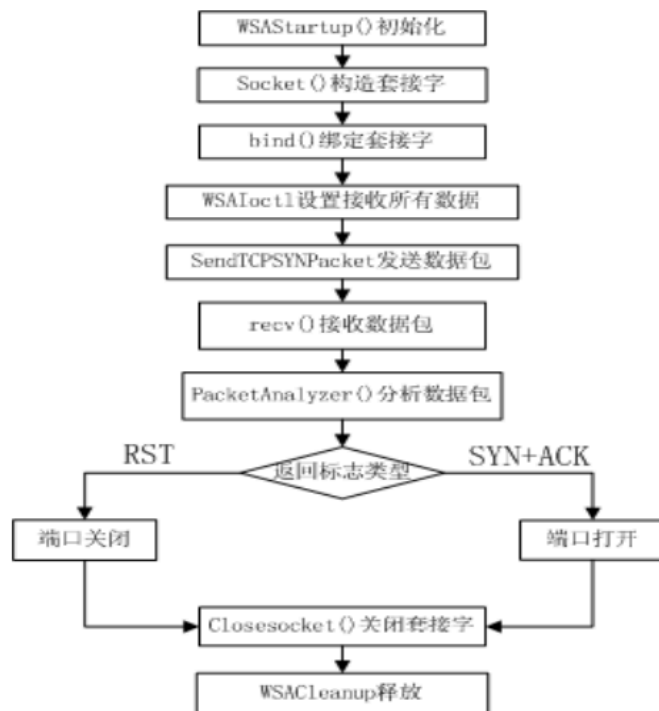


- 优点：
 - 扫描迅速
 - 准确而且不需要任何权限，系统中的任何用户可以使用这个调用
 - 可以同时打开多个套接字，加速扫描，使用非阻塞I/O还允许设置一个低的时间用尽周期，同时观察多个套接字
- 缺点：
 - 扫描方式不隐蔽，服务器日志会记录下大量密集的连接和错误记录
 - 易被目标主机防火墙发觉而被过滤掉
- **TCP反向ident扫描**：ident协议允许（RFC1413）看到通过TCP连接的任何进程的拥有者的用户名，即使这个连接不是由这个进程开始的。

半连接扫描

- TCP SYN扫描

- 流程



- 扫描者发送一个 **SYN** 包到目标端口。如果收到 **SYN/ACK**，说明端口是**开放**的。扫描者在收到 SYN/ACK 后，**不发送**最后的 ACK 包，而是发送一个 **RST（重置）** 包来立刻中断连接。
- 优点：
 - 扫描迅速快，效率高
 - 一般不会在目标计算机上留下记录，比较隐蔽
- 缺点：
 - 在大部分操作系统下，扫描主机需要构造适合于这种扫描的包，而通常情况下，必须要有root权限才能建立自己的SYN数据包

防火墙

基础

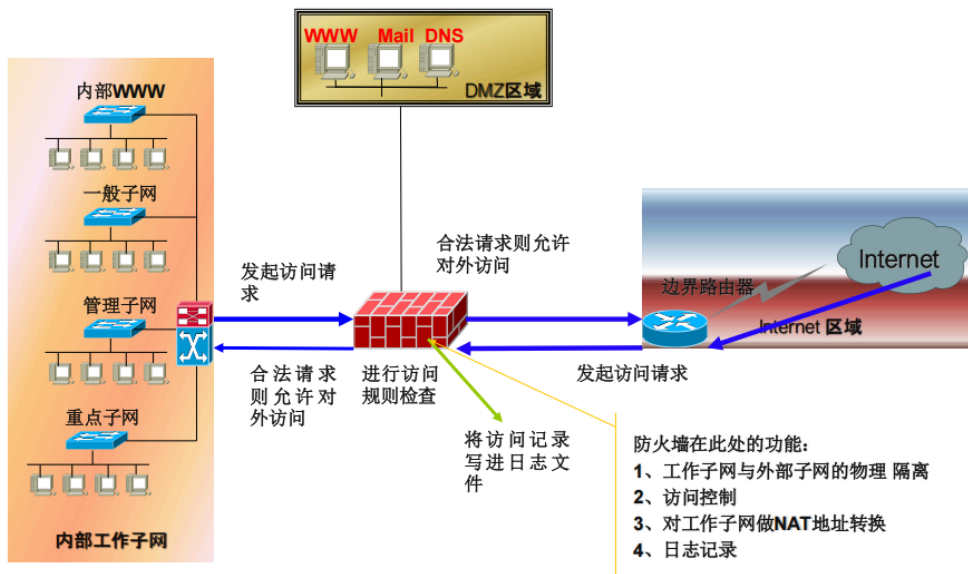
- 访问控制包括三个要素：主体、客体和控制策略
 - 主体S：是指提出访问资源具体请求。是某一操作动作的发起者，但不一定是动作的执行者，可能是某一用户，也可以是用户启动的进程、服务和设备等。
 - 客体O：是指被访问资源的实体。所有可以被操作的信息、资源、对象都可以是客体。客体可以是信息、文件、记录等集合体，也可以是网络上硬件设施、无限通信中的终端，甚至可以包含另外一个客体。
 - 控制策略A：是主体对客体的相关访问规则集合，即属性集合。访问策略体现了一种授权行为，也是客体对主体某些操作行为的默认。
- 访问控制策略：
 - 安全策略的实施原则：安全策略的制定实施也是围绕主体、客体和安全管理规则三者之间的关系展开的。

1. **最小特权原则**：最小特权原则是指主体执行操作时，按照主体所需权利的最小化原则分配给主体权力。最小特权原则的优点是最大限度地限制了主体实施授权行为，可以避免来自突发事件、错误和未授权用主体的危险。也就是说，为了达到一定目的，主体必须执行一定操作，但他只能做他所被允许做的，其它除外。
 2. **最小泄漏原则**：最小泄漏原则是指主体执行任务时，按照主体所需要知道的信息最小化的原则分配给主体权力。
 3. **多级安全策略**：多级安全策略是指主体和客体间的数据流向和权限控制按照安全级别的**绝密 (TS)、秘密 (S)、机密 (C)、限制 (RS) 和无级别 (U)** 五级来划分。多级安全策略的优点是避免敏感信息的扩散。具有安全级别的信息资源，只有安全级别比他高的主体才能够访问。
- **自主访问控制模型DAC**：
 - 概念：根据自主访问控制策略建立的一种模型，允许合法用户以用户或用户组的身份访问策略规定的客体，同时阻止非授权用户访问客体，某些用户还可以自主地把自己所拥有的客体的访问权限授予其它用户。
 - 自主访问控制又称为任意访问控制。Linux, UNIX、Windows NT或是SERVER版本的操作系统都提供自主访问控制的功能。
 - 在实现上，首先要对用户的身份进行鉴别，然后就可以按照访问控制列表所赋予用户的权限允许和限制用户使用客体的资源。主体控制权限的修改通常由特权用户或是特权用户（管理员）组实现。
 - **强制访问控制模型MAC**：
 - 概念：一种多级访问控制策略。系统对访问主体和受控对象实行强制访问控制，系统事先给访问主体和受控对象分配不同的安全级别属性，实施访问控制时，系统先对访问主体和受控对象的安全级别属性进行比较，再决定访问主体能否访问该受控对象。
 - MAC对访问主体和受控对象标识两个安全标记：一个是具有偏序关系的安全等级标记（安全级别）；另一个是非等级分类标记（所属部门）。当主体s的安全类别为TS，而客体o的安全类别为S时，用偏序关系可以表述为 $SC(s) \geq SC(o)$ 。
 - 主体对客体的访问主要有四种方式：
 - 向下读（rd, read down）：主体安全级别高于客体信息资源的安全级别时允许查阅的读操作；
 - 向上读（ru, read up）：主体安全级别低于客体信息资源的安全级别时允许的读操作；
 - 向下写（wd, write down）：主体安全级别高于客体信息资源的安全级别时允许执行的动作或是写操作；
 - 向上写（wu, write up）：主体安全级别低于客体信息资源的安全级别时允许执行的动作或是写操作。
 - **Bell-LaPadula (BLP) 模型**：
 - 典型的信息保密性多级安全模型，主要应用于军事系统。
 - 无上读（防止被低级别的人看到），无下写（防止把信息泄漏到低级别内容）
 - 通常是处理多级安全信息系统的设计基础，客体在处理绝密级数据和秘密级数据时，要防止处理绝密级数据的程序把信息泄露给处理秘密级数据的程序。
 - 机密性 、完整性 

- **Biba模型：**
 - 禁止向上写（怕污染高级数据），没有向下读（怕被污染）
 - 在信息流向的定义方面不允许从级别低的进程到级别高的进程，也就是说用户只能向比自己安全级别低的客体写入信息，从而防止非法用户创建安全级别高的客体信息，避免越权、篡改等行为的产生。
 - 可同时针对有层次的安全级别和无层次的安全种类
 - 机密性 ❌、完整性 ✅

防火墙

- 定义：位于两个(或多个)网络间实施网间访问控制的一组组件的集合。
- 满足条件：
 - 所有进出被保护网络的通信必须通过防火墙
 - 所有通过防火墙的通信必须经过安全策略的过滤或者防火墙的授权
 - 防火墙自身应对渗透（penetration）免疫
- 典型使用形态



- 功能：
 - 内容过滤
 - 用户认证
 - VPN
 - 应用程序代理：工作在OSI模型的最高层（应用层）。它不直接允许外部数据包进入内网，而是由防火墙作为“中介”接收请求，经过深度检查（去毒、过滤）后，再由防火墙转发给内部服务器。这能有效隐藏内网拓扑并阻止针对应用层协议的攻击。
 - 访问控制（最基本、最核心）
 - IDS与报警
 - NAT
 - 日志
- 访问控制方法：
 - 服务控制：确定可以访问的服务类型；

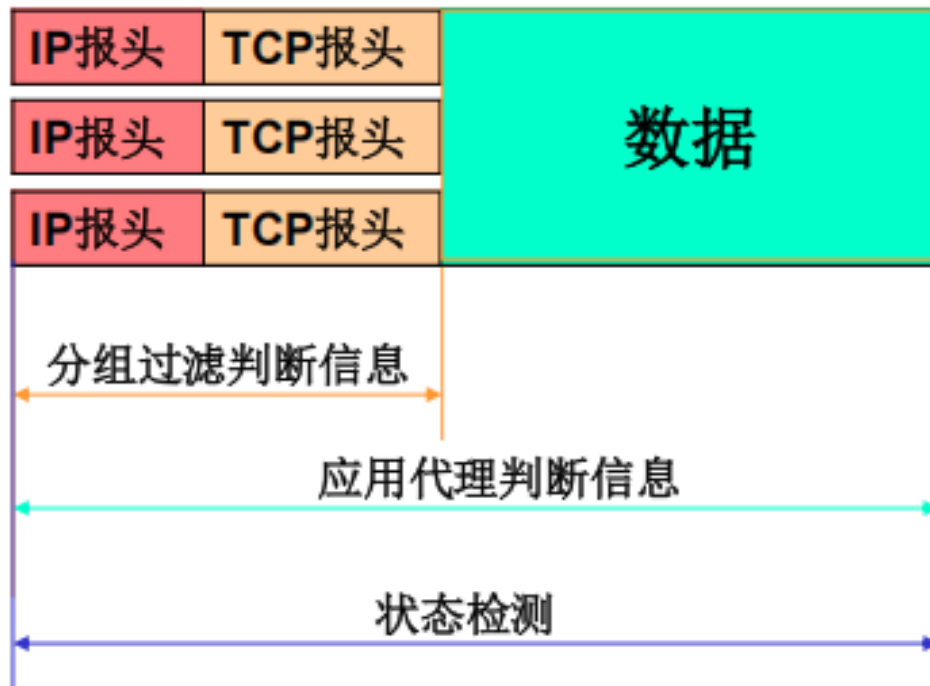
- 方向控制：确定特定的服务请求可以发起并允许通过防火墙；
- 用户控制：不同的用户具有不同服务访问的权限；
- 行为控制：控制怎样使用特定服务。如过滤垃圾邮件
- 分类：
 - 形态：软件、硬件防火墙
 - 实现技术 (*)：包过滤防火墙、应用网关防火墙、代理防火墙、状态检测防火墙、电路级网关
 - 部署位置：主机、网络防火墙
- **包过滤防火墙**
 - 对所接收的每个数据包做允许、拒绝的决定，防火墙审查每个数据报以便确定其是否与某一条包过滤规则匹配。
 - 过滤规则基于可以提供给IP转发过程的包头信息。
 - 分类：静/动态包过滤
 - 动态包过滤对外出数据包的身份做一个标记，对相同连接的进入的数据包也被允许通过，也就是说，它捕获了一个“连接”，而不是单个数据包头中的信息。
 - 判断依据：

- **基本信息**
 - 地址信息：源、目的IP地址
 - 协议信息：数据包协议类型TCP、UDP、ICMP、IGMP等
 - 源、目的端口FTP、HTTP、DNS等
- **协议具体信息**
 - IP选项源路由、记录路由等
 - TCP选项SYN、ACK、FIN、RST等
 - 其它协议选项ICMP、ECHO、ICMP、ECHO、REPLY等
- **流向及接口信息**
 - 数据包流向in或out
 - 数据包流经网络接口eth0 eth1

- 优点：
 - 逻辑简单，价格便宜，**成本低**；
 - 对网络性能的影响较小，有较强的**透明性**。
 - 易于匹配绝大多数网络层、传输层数据包，定制策略**灵活**。
 - 并且它的工作与应用层无关，无须改动任何客户机和主机上的应用程序，易于安装和使用，**方便**。

- 缺点：
 - 需要对IP、TCP、UDP、ICMP等协议有深入了解，容易出现因**配置不当**带来的问题；
 - 过滤判别的只有网络层和传输层的**有限信息**（应用层数据无法处理），因而各种安全要求不能得到充分满足；
 - 由于数据包的地址及端口号都在数据包的头部，不能彻底防止**IP地址欺骗**；
 - 允许外部客户和内部主机的**直接连接**；
 - 不提供**用户的鉴别机制**；
 - 仅工作在**网络层**，提供较低水平的安全性。
- **应用网关防火墙（AGF）**
 - 又称代理防火墙或简称应用网关，在应用层处理信息，在请求方和服务方中间充当代理角色，使得双方永不建立真正连接
 - AGF可以支持多个应用，如E-mail，Web，DNS，Telnet，FTP等
 - 工作过程：
 - 首先，它对该用户的身份进行验证
 - 若为合法用户，则把请求转发给真正的某个内部网络的主机，同时监控用户的操作，拒绝不合法的访问（访问权限）。
 - 当内部网络向外部网络申请服务时，代理服务器的工作过程刚好相反。（认证输入、输出两个方向的连接）
 - 优点：
 - 不允许内外网主机的直接连接；
 - 可以提供比包过滤更详细的日志记录（应用层信息）；
 - 可以隐藏内部IP地址；
 - 认证用户而非设备；
 - 可以为用户提供透明的加密机制；
 - 可以与认证、授权等安全手段方便的集成；
 - 监控、过滤应用层信息；
 - 缺点：
 - 代理速度比包过滤**慢**；
 - 代理对用户**不透明**，给用户的使用带来不便，灵活性不够；
 - 这种代理技术需要针对每种协议设置一个不同的代理服务器；
 - 有时要求特定的客户端软件，**麻烦**
- **状态检测防火墙：**
 - 在动态包过滤防火墙基础上，增加了状态检测机制而形成的
 - 具有连接的跟踪能力
 - 优点：具备动态包过滤的所有优点，同时具有更高的安全性。
 - 缺点：
 - 检测的层次仅限于网络层与传输层，无法对应用层内容进行检测，从而无法抵抗应用层的攻击；

- 性能比动态包过滤稍差：因为检测更多的内容。



NAT 网络地址翻译

- 作用：将一个IP地址用另一个IP地址代替
- 目的：
 - 解决IP地址空间不足问题
 - 向外界隐藏内部网结构
- 方式：
 - M-1：多个内部网地址翻译到1个IP地址
 - 1-1：简单的地址翻译
 - M-N：多个内部网地址翻译到N个IP地址池
- 类型
 - 静态NAT：内部网络每个主机都永久映射成外部合法的地址
 - NAT池：在外部网络中定义了一系列合法地址，采用动态分配的方法映射到内部网络
 - 端口NAT（PNAT）：把内部地址映射到外部网络的一个IP地址的不同端口上

防火墙体系结构

- **双重宿主主机体系结构**
 - 围绕双重宿主主机构筑的
 - 双重宿主主机至少有两个网络接口：
 - 它位于内部网络和外部网络之间，这样的主机可以充当与这些接口相连的网络之间的路由器，它能从一个网络接收IP数据包并将之发往另一网络。
 - 双重宿主主机的防火墙体系结构禁止这种发送功能，完全阻止了内外网络之间的IP通信。
 - 两个网络之间的通信可通过应用层数据共享和应用层代理服务的方法实现。一般情况

下采用代理服务的方法。

- 特性：
 - 安全至关重要（唯一通道），其用户口令控制安全是关键
 - 必须支持很多用户的访问（中转站），其性能非常重要
- 缺点：双重宿主主机是隔开内外网络的唯一屏障，一旦它被入侵，内部网络便向入侵者敞开大门。

• 屏蔽主机体系结构

- 由防火墙和内部网络的堡垒主机承担安全责任。一般这种防火墙较简单，可能就是简单的路由器。
- 典型构成：**包过滤路由器 + 堡垒主机**
 - 包过滤路由器配置在内部网和外部网之间，保证外部系统对内部网络的操作只能经过堡垒主机。
 - 堡垒主机配置在内部网络上，是外部网络主机连接到内部网络主机的桥梁，它需要拥有高等级的安全。
- 屏蔽路由器可按如下规则之一进行配置：
 - 允许内部主机为了某些服务请求与外部网上的主机建立直接连接（即允许那些经过过滤的服务）。
 - 不允许所有来自外部主机的直接连接。
- 优点：安全性更高，双重保护：实现了网络层安全（包过滤）和应用层安全（代理服务）。
- 缺点：过滤路由器能否正确配置是安全与否的关键。如果路由器被损害，堡垒主机将被穿过，整个网络对侵袭者是开放的。
- 重点在于路由器的配置和堡垒机的安全性。

• 屏蔽子网体系结构

- 在本质上与屏蔽主机体系结构一样，但添加了额外的一层保护体系——周边网络。堡垒主机位于周边网络上，周边网络和内部网络被内部路由器分开。
- 周边网络：
 - 一个防护层，在其上可放置一些信息服务器，它们是牺牲主机，可能会受到攻击，因此又被称为非军事区（DMZ）。
 - 作用：即使堡垒主机被入侵者控制，它仍可消除对内部网的侦听。
- 堡垒主机：
 - 堡垒主机位于周边网络，是整个防御体系的核心。
 - 堡垒主机可被认为是应用层网关，可以运行各种代理服务程序。
 - 对于出站服务不一定要要求所有的服务经过堡垒主机代理，但对于入站服务应要求所有服务都通过堡垒主机。
- 外部路由器（访问路由器）：
 - 它把入站的数据包路由到堡垒主机，防止部分IP欺骗，它可分辨出数据包是否真正来自周边网络，而内部路由器不可。
 - 作用：保护周边网络和内部网络不受外部网络的侵犯
- 内部路由器（阻塞路由器）：

- 作用：保护内部网络不受外部网络和周边网络的侵害，它执行大部分过滤工作。
- 外部路由器一般与内部路由器应用相同的规则。
- 优点：
 - 入侵者需突破3个不同的设备才能入侵内部网络
 - 只对外通告DMZ区的网络，保证内部网络不可见
 - 内部网络用户通过堡垒主机或代理服务器访问外部网络

IDS

IDS的历史

- 概念的诞生：1980年4月，《计算机安全威胁监控与监视》第一次详细阐述了入侵检测的概念，将威胁分为外部渗透、内部渗透和不法行为三种；
- 模型的发展：1984-1986年，一个实时入侵检测系统IDES（入侵检测专家系统）；
- 里程碑的产生：1990年，NSM。该系统第一次直接将网络流作为审计数据来源；从此入侵检测系统发展史形成了两大阵营：基于网络的IDS和基于主机的IDS。

入侵检测概念

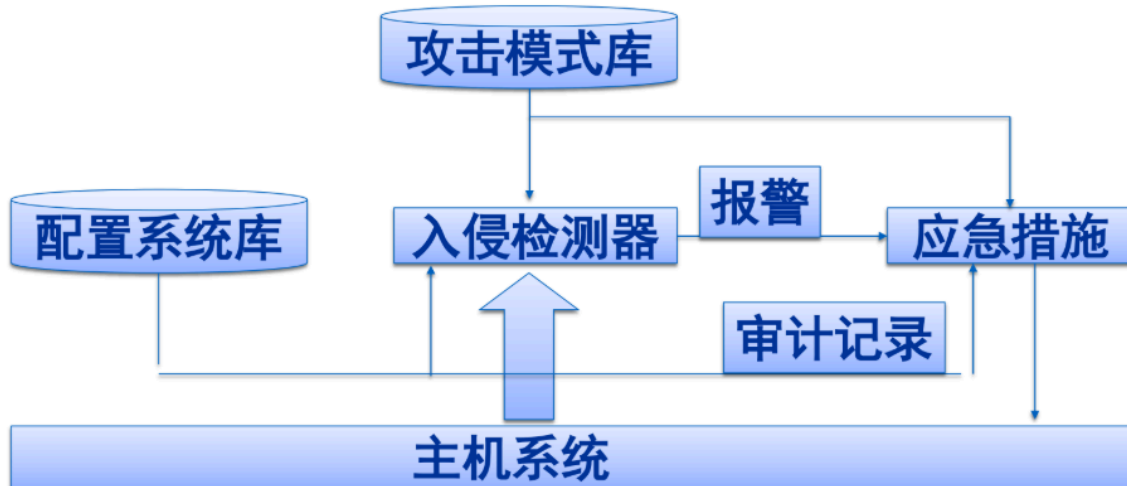
- 入侵检测是从计算机网络或计算机系统若干关键点搜集信息并对其进行分析，从中发现网络或系统中是否有**违反安全策略的行为和遭到袭击的迹象**的一种机制。
- 一种**主动保护自己的网络和系统免遭非法攻击的网络安全技术**。
- 安全审计中的核心技术之一

入侵检测的分类

- **根据原始数据的来源**
 - 基于**主机**的入侵检测系统：监控粒度更细、配置灵活、可用于加密的以及交换的环境
 - 基于**网络**的入侵检测系统：视野更宽、隐蔽性好、攻击者不易转移证据
- **根据检测原理**
 - 异常入侵检测：根据异常**行为**和使用**计算机资源**的情况检测出来的入侵。（行为检测）
 - 误用入侵检测：利用已知系统和应用程序的弱点攻击**模式**来检测入侵。（黑名单检测）
- **根据体系结构**
 - 集中式：多个分布于不同主机上的审计程序，一个入侵检测服务器
 - 等级式：定义了若干个分等级的监控区域，每个IDS负责一个区域，然后将当地的分析结果传送给上一级IDS
 - 协作式：将中央检测服务器的任务分配给多个基于主机的IDS，这些IDS不分等级，各司其职，负责监控当地主机的某些活动。
- **根据工作方式分类**
 - 离线检测：非实时工作系统，在事件发生后分析审计事件，从中检查入侵事件。

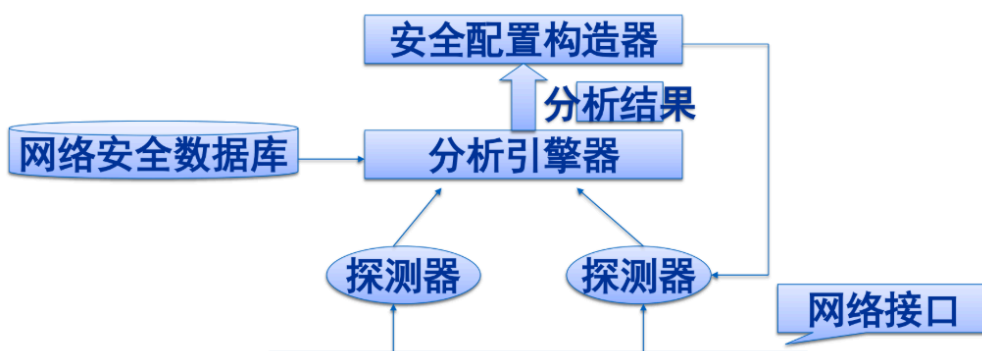
- 在线检测：对网络数据包或主机的审计事件进行实时分析，可以快速反应，保护系统的安全；但系统规模较大时，难以保证实时性。

基于主机系统结构HIDS：Host-Based IDS



- 检测的目标主要是主机系统和系统本地用户。检测原理是根据主机的审计数据和系统的日志发现可疑事件，检测系统可以运行在被检测的主机或单独的主机上。
- 优点
 - 性价比高
 - 细腻性，审计内容全面
 - 视野集中
 - 适用于加密及交换环境
- 缺点
 - IDS的运行影响服务器的性能
 - HIDS依赖性强，依赖于审计数据或系统日志准确性和完整性，以及安全事件的定义。
 - 如果主机数目多，代价过大
 - 不能监控网络上的情况

基于网络系统结构NIDS：Network-Based IDS

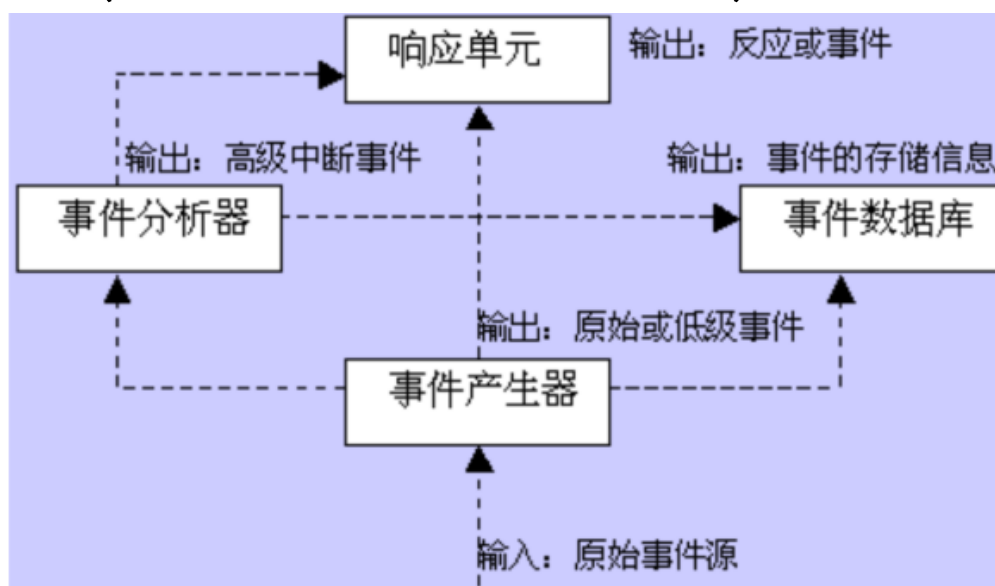


- 根据网络流量、协议分析、单台或多台主机的审计数据检测入侵。
- NIDS优点：

- 服务器平台独立性：监视通信流量而不影响服务器的平台的变化和更新；
- 配置简单：只需要一个普通的网络访问接口即可；
- 众多的攻击标识：探测器可以监视多种多样的攻击包括协议攻击和特定环境的攻击。
- **NIDS缺点**
 - 不能检测不同网段的网络包
 - 很难检测复杂的需要大量计算的攻击
 - 协同工作能力弱
 - 难以处理加密的会话

入侵检测结构

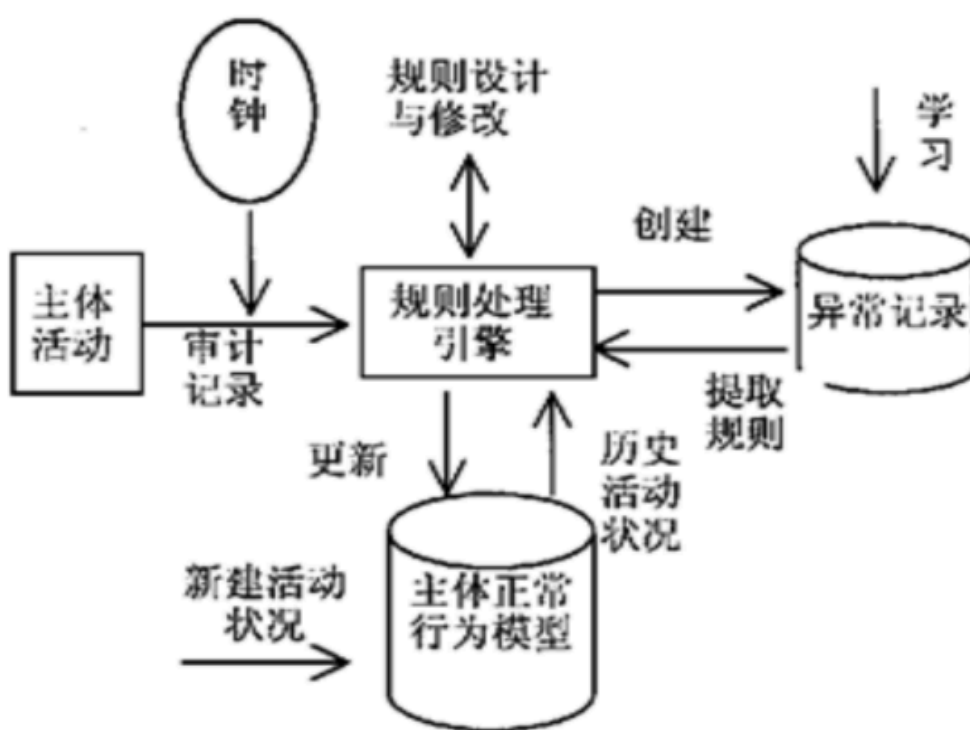
- **CIDF (Common Intrusion Detection Framework)**



- **事件产生器 (Event Generators)**
 - 事件产生器的目的是从整个计算环境中获得事件，并向系统的其他部分提供此事件。
 - 入侵检测的第一步
 - 采集内容包括系统日志、应用程序日志、系统调用、网络数据、用户行为、其他IDS的信息
- **事件分析器 (Event analyzers)**
 - 事件分析器分析得到的数据，并产生分析结果。
 - 分析是核心，效率高低直接决定整个IDS性能
- **响应单元 (Response units)**
 - 响应单元则是对分析结果作出作出反应的功能单元，功能包括：
 - 告警和事件报告
 - 终止进程，强制用户退出
 - 切断网络连接，修改防火墙设置
 - 灾难评估，自动恢复
 - 查找定位攻击者
- **事件数据库 (Event databases)**

- 事件数据库是存放各种中间和最终数据的地方的统称，它可以是复杂的数据库，也可以是简单的文本文件。

• Denning模型



- 1987年提出的一个通用入侵检测模型
- 主体 (Subjects)：在目标系统上活动的实体，如用户。
- 对象 (Objects)：指系统资源，如文件、设备、命令等。
- 审计记录 (Audit records)：由主体、活动（主体对目标的操作）、异常条件（系统对主体的该活动的异常情况的报告）、资源使用状况（系统的资源消耗情况）和时间戳（Time-Stamp）等组成。
- 活动档案 (Active Profile)：即系统正常行为模型，保存系统正常活动的有关信息。
- 异常记录 (Anomaly Record)：由事件、时间戳和审计记录组成，表示异常事件的发生情况。
- 活动规则 (Active Rule)：判断是否为入侵的准则及相应要采取的行动。

入侵检测技术

• 异常检测技术

- 思想：任何正常人的行为有一定的规律，而入侵会引起用户或系统行为的异常
- 需要考虑的问题：
 - 选择哪些数据来表现用户的行为
 - 通过以上数据如何有效地表示用户的行为，主要在于学习和检测方法的不同
 - 考虑学习过程的时间长短、用户行为的时效性等问题
- 典型算法：统计分析（均值、偏差、Markov过程）
- 异常检测模型：首先总结正常操作应该具有的特征（用户轮廓），当用户活动与正常行为有重大偏离时即被认为是入侵
- 检测原理

- 正常行为的特征轮廓
- 检查系统的运行情况
- 是否偏离预设的门限?
- 举例：多次错误登录、午夜登录
- **优点：**
 - 可以检测到未知的入侵
 - 可以检测冒用他人帐号的行为
 - 具有自适应，自学习功能
 - 不需要系统先验知识
- **缺点：**
 - 漏报相对低、误报率相对高
 - 统计算法的计算量庞大，效率很低
 - 统计点的选取和参考库的建立比较困难
- **统计分析：**
 - 依据系统中特征变量的历史数据建立统计模型，并运用该模型对特征变量未来的取值进行预测和检测偏离
 - 典型的系统主体特征有：系统中的特征变量有用户登录失败次数、CPU和I/O利用率、文件访问数及访问出错率、网络连接数、击键频率、事件间的时间间隔等。
 - **缺点：**
 - 未考虑事件的发生**顺序**，所以对利用事件顺序关系的攻击难以检测；
 - （容易被带偏）利用统计轮廓的动态自适应性，通过缓慢改变其行为来训练正常特征轮廓，最终使检测系统将其异常活动判为正常；
 - 难以确定**门限值**。
 - **统计分析模型分类：**
 - (a) **均值与标准偏差模型**。以**单个特征变量**为检测对象，假定特征变量满足正态分布，根据该特征变量的历史数据统计出分布参数（均值、标准偏差），并依此设定信任区间。在检测过程中，若特征变量的取值超出信任区间，则认为发生异常。
 - (b) **多元模型**。以**多个特征变量**为检测对象，分析多个特征变量间的相关性，是均值与标准偏差模型的扩展，不仅能检测到单个特征变量值的偏离，还能检测到特征变量间关系的偏离。
 - (c) **Markov过程模型**。将每种类型的事件定义为系统的一个状态，用状态转换矩阵来表示状态的变化，若对应于所发生事件的状态转移概率较小，则该事件可能为异常事件。
 - (d) **时间序列模型**。将事件计数与资源消耗根据时间排列成序列，如果某一新事件在相应时间发生的概率较低，则该事件可能为入侵。
- **误用检测技术**
 - 思想：主要是通过某种方式预先定义入侵行为，然后监视系统，从中找出符合预先定义规则的入侵行为

- 误用信号需要对入侵的特征、环境、次序以及完成入侵的事件相互间的关系进行描述
- 重要问题
 - 如何全面的描述攻击的特征
 - 如何排除干扰，减小误报
 - 解决问题的方式
- 典型算法：专家系统、模型推理、完整性分析
- 优点：
 - 算法简单
 - 系统开销小
 - 准确率高
 - 效率高
- 缺点：
 - 被动：只能检测出已知攻击、新类型的攻击会对系统造成很大的威胁
 - 模式库的建立和维护难：模式库要不断更新，知识依赖于硬件平台、操作系统和系统中运行的应用程序等
- 专家系统
 - 将有关入侵的知识转化为if-then结构的规则，即将构成入侵所要求的条件转化为if部分，将发现入侵后采取的相应措施转化成then部分。
 - 专家系统主要面临：
 - 全面性问题，即难以科学地从各种入侵手段中抽象出全面的规则化知识；
 - 效率问题，即所需处理的数据量过大，而且在大型系统上，如何获得实时连续的审计数据也是个问题。
- 模型推理
 - 模型推理是指结合攻击脚本推理出入侵行为是否出现。
 - 其中有关攻击者行为的知识被描述为：攻击者目的，攻击者达到此目的的可能行为步骤，以及对系统的特殊使用等。
 - 根据这些知识建立攻击脚本库，每一脚本都由一系列攻击行为组成。
 - 减少了需要处理的数据量，如何有效地翻译攻击脚本是问题。

snort

- 典型的误用检测技术
- 基于攻击特征匹配的原理，需要准确理解攻击模式并撰写检测规则
- 无法应对未知攻击，造成漏报
- 检测效率高、准确率高
- 攻击规则更新要求高，好在攻击方式变化不剧烈
- *e. g.*
 - **DoS检测——Land**
 - 检测方法：判断网络数据包的源地址和目标地址是否相同。
 - Snort规则：`alert ip $HOME_NET any -> $HOME_NET any (msg:"DoS Land attack"; flags:S; flow: stateless classtype:attempted-dos;`

```
sid:6001; rev:1;sameip)
```

- 数据包中flags字段的值是SYN。
- sameip关键字允许规则检测源IP和目的IP是否相等。
- **扫描检测——TCP NULL扫描**
 - 攻击目的：可以判断目标主机操作系统是windows还是类Unix系统。
 - 攻击原理：根据RFC 793，类Unix系统接收到没有设置任何标志位的数据包，端口关闭的情况下舍弃掉该数据包并且发送一个RST数据包，端口开放的话不会响应；而Windows系统不满足RFC 793，当收到该数据包的情况下，无论端口开放或者关闭，都会响应一个RST数据包给发送方。
 - 检测方法：验证数据包中所有标志位是否都为0。
 - Snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"SCAN NULL";flags:0; flow: from_client; classtype:attempted-recon; sid:6002; rev:1;)
```
- **漏洞利用检测——SQL注入漏洞**
 - 检测方法：验证数据包中的内容中是否存在 `'or 1=1 #`
 - Snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"SQL Injection found"; flow:from_client, established; content: "'%20and%201=1#"; classtype:web-application-attack; sid:6003; rev:1;)
```

 - 包的净荷中含有“`'%20and%201=1#`”，在报警和包日志中打印“SQL Injection found”

VPN

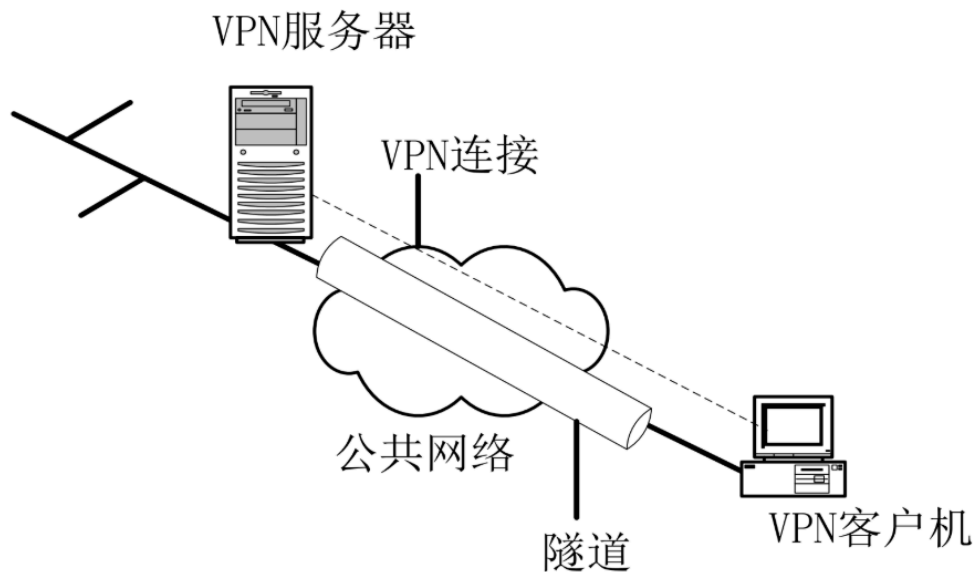
VPN提出与解决的问题

- **提出背景**：在端到端的数据通路上随处都有可能发生数据的泄漏，包括：拨入段链路上、ISP接入设备上、在因特网上、在安全网关上、在企业内部网上。
- **解决目标**：提供一个综合一致的解决方案，不仅能提供端到端的数据保护，同时也能提供逐段的数据保护。

定义与构成

- **VPN (Virtual Private Network) 虚拟专用网**
 - 定义：指依靠ISP或其他NSP在公用网络基础设施之上构建的专用的数据通信网络。
 - 公用网络包括：IP网络、帧中继网络、ATM网络。
 - “虚拟”：指使用公用网络。
 - “专用网”特点：封闭的用户群、安全性高、服务质量保证。
 - IETF定义：使用IP机制仿真出一个私有的广域网。

- VPN的构成

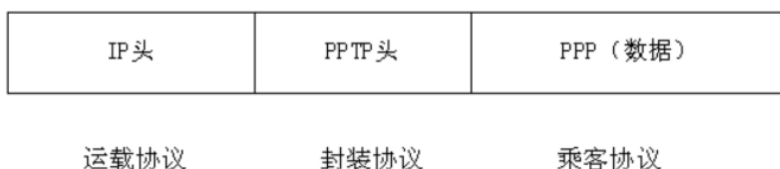


VPN的特点与实现要求

- 专用网的特点
 - 封闭的用户群
 - 安全性高
 - 服务质量保证
- VPN的实现要求
 - 支持数据分组的透明传输
 - 支持安全功能
 - 提供服务质量保证

VPN技术

- 隧道技术
 - 隧道是在公共通信网络上构建的一条数据路径，可以提供与专用通信线路等同的连接特性。
 - 隧道使用隧道协议来封装数据。将一种协议（协议X）封装在另一种协议（协议Y）中传输，从而实现协议X对公用传输网络（采用协议Y）的透明性。
 - 协议X称为乘客协议，协议Y称为封装协议。
 - 隧道协议内包括三种协议：乘客协议、封装协议、运载协议。
- 例子：



VPN分类

- 按VPN业务类型划分

- Intranet VPN（内部公文流转）
- Access VPN（远程拨号VPN）
- Extranet VPN（各分支机构互联）
- **按VPN发起主体划分**
 - 客户发起，也称基于客户的VPN
 - 服务器发起，也称客户透明方式或基于网络的VPN

VPN应用类型

- **Client-LAN类型 (Access VPN)**
 - 远程访问方式的VPN。
 - 适用场景：出差员工、有远程办公需要的分支机构。
 - 细分：基于Internet远程访问的VPN，基于Intranet远程访问的VPN。
- **LAN-LAN类型**
 - 利用基本的Internet和Intranet网络建立物理连接，再利用VPN隧道协议（如IPSec）实现安全保密需要。
 - 适用场景：公司总部与分支机构以及合作企业间的安全网络连接。
 - 细分：
 - Intranet VPN：用于构建内联网。
 - Extranet VPN：用于企业和合作企业进行网络互联。

VPN功能

- 数据机密性保护
- 数据完整性保护
- 数据源身份认证
- 重放攻击保护

PPTP（点对点通道协议）

- **基本情况**
 - 提供PPTP客户机和PPTP服务器之间的加密通信。
 - 可看作是PPP协议的一种扩展。
 - 提供了一种在Internet上建立多协议（TCP/IP、IPX、NetBEUI）的安全虚拟专用网的通信方式。
 - 由微软公司设计，用于将PPP分组通过IP网络封装传输。
- **数据封装**
 - 格式：数据链路层报头 | IP报头 | GRE报头 | PPP报头 | 加密PPP有效载荷 | 数据链路层报尾。
 - 处理过程：处理并去除各层报头报尾（数据链路层、IP、GRE（数据通道）、PPP），对PPP有效载荷进行解密或解压缩，对传输数据进行接收或转发处理。
- **工作机制**

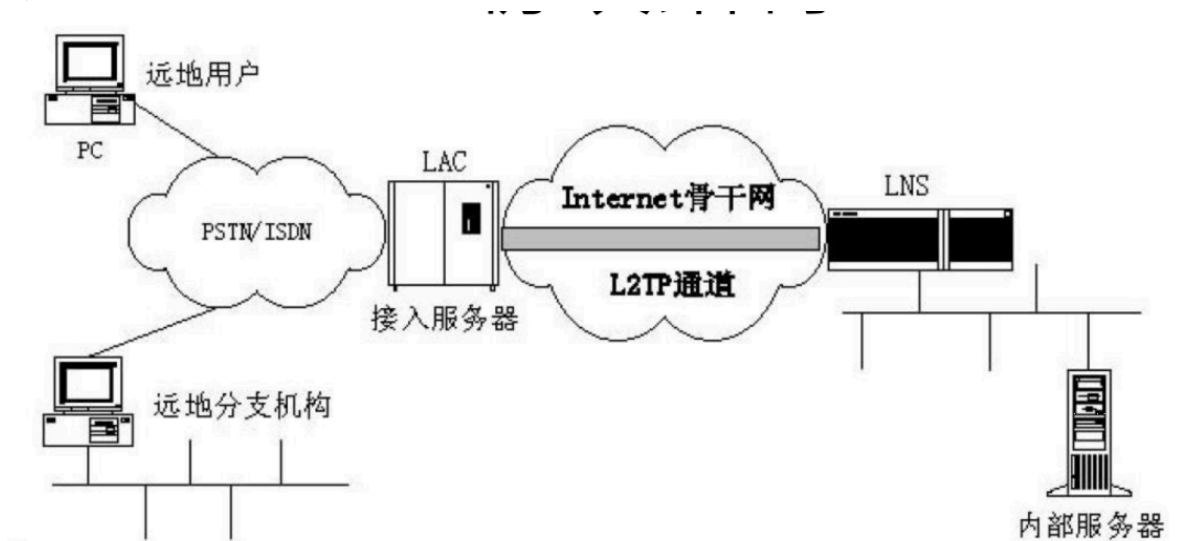
- 客户按常规方式拨号到ISP接入服务器（NAS），建立PPP连接。
- 客户进行二次拨号建立到PPTP服务器的连接（PPTP隧道）。
- PPTP只支持IP作为传输协议。
- 采用了基于RSA公司RC4的数据加密方法。

L2TP（第二层通道协议）

• 基本情况

- 结合了L2F和PPTP的优点。可以从客户端发起VPN连接，把链路层PPP帧封装在公共网络设施（如IP、ATM、帧中继）中进行隧道传输。

• 协议结构

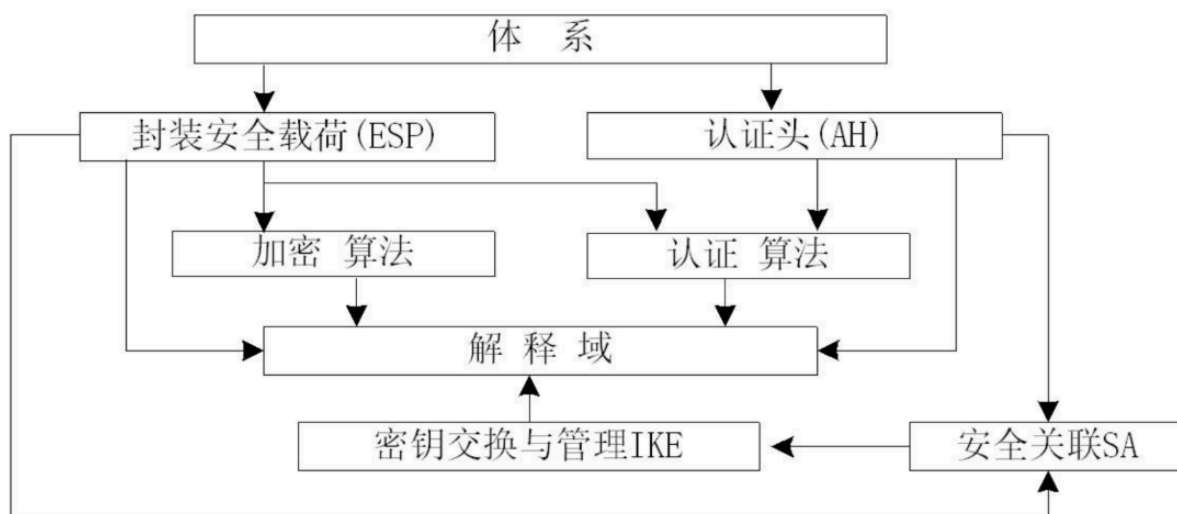


- LAC (L2TP Access Concentrator): L2TP访问集中器，通常是网络接入服务器NAS，用于发起呼叫、接收呼叫和建立隧道。
- LNS (L2TP Network Server): L2TP网络服务器，是所有隧道的终点，用于处理L2TP协议服务器端部分。
- 支持多种协议：
 - 支持多个PPP链路的捆绑问题：物理上连接不同NAS，逻辑上终结点为同一个物理设备。
 - 扩展了PPP连接：第2层连接的终结点（LAC）和PPP会话的终结点（LNS）可以是不同的设备。

IPSec（IP层安全协议）

- 通过对IP报文的封装以实现TCP/IP网络上数据的安全传送。

• 体系结构



- 核心协议：封装安全载荷 (ESP)、认证头 (AH)。

• AH协议 (认证头)

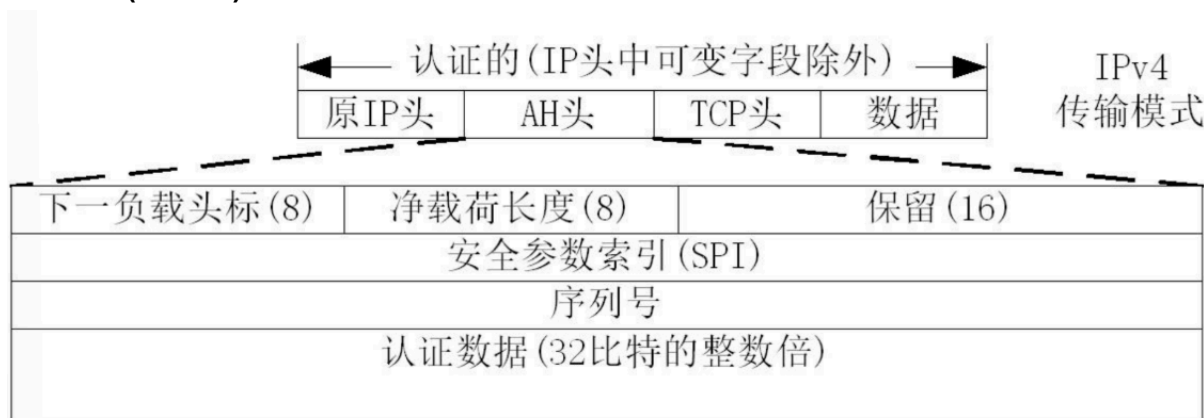


图 AH的格式

- 提供认证（数据源认证、完整性）和抗重放攻击，**不提供加密**。
- 传输模式：原IP头 | AH头 | TCP头 | 数据。认证除IP头中可变字段外的所有内容。
- 隧道模式：新IP头 | AH头 | 原IP头 | TCP头 | 数据。认证包括新IP头、AH头、原IP头及数据。（原IP为主机IP，新IP为网关IP，网关负责处理）

• ESP协议 (封装安全载荷)



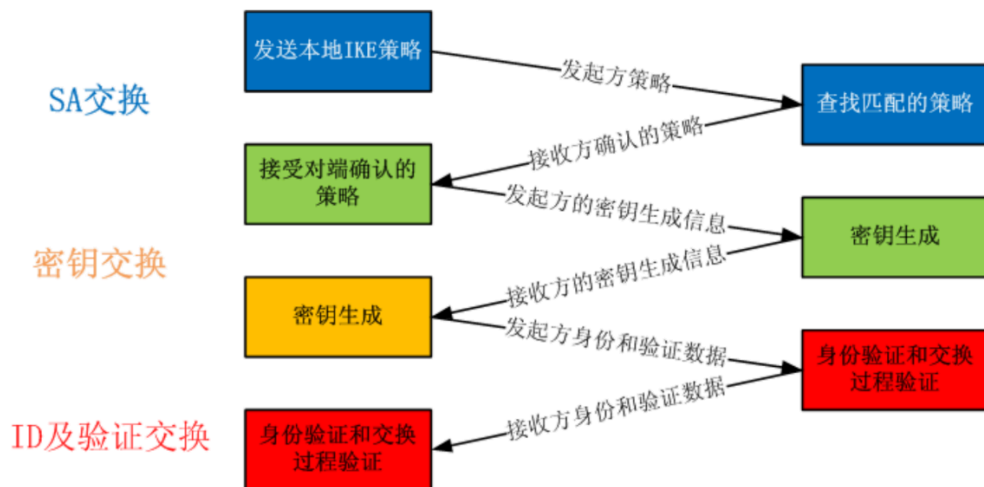
图 ESP格式

- 提供机密性（加密）、数据源认证、数据完整性、抗重放攻击。注意ESP尾部属于加密部分
- 传输模式：IP头 | ESP头 | TCP头 | 数据 | ESP尾 | ESP认证。加密部分为TCP头+数据+ESP尾。
- 隧道模式：新IP头 | ESP头 | 原IP头 | TCP头 | 数据 | ESP尾 | ESP认证。加密部分为原IP头+TCP头+数据+ESP尾。
- **实施模式**
 - 传输模式：适合于保护主机之间的连接。
 - 隧道模式：适合于保护网络之间的连接（VPN网关之间）。
- **安全联盟数据库 (SADB)**
 - SA (Security Association)：两个IPSec通信实体间协商建立的共同协定。
 - 常用参数：加密及验证密钥、密码算法标识、序列号、抗重播窗口、生存周期、实施模式、隧道目的地址、SPI。
- **处理流程**
 - 数据包输出：截取IP包 -> 搜索SPD (安全策略数据库) -> 决定丢弃/通过/应用IPSec (指向SA或触发IKE协商) -> 发送。
 - 数据包输入：收到IPSec包 -> 从头部提取<dst_ip, protocol, SPI> -> 搜索SADB -> 找到SA则解封装 -> 提取原始IP包选择符 -> 搜索SPD验证策略 -> 符合则转入系统IP协议栈。

IKE (互联网密钥交换)

- **基本情况**
 - Internet Key Exchange。
 - 功能：在IPSec通信双方之间通过协商建立起共享安全参数及验证过的密钥（建立安全联盟）。
 - 协议基础：Oakley和SKEME协议的混合，在ISAKMP框架内运作。
- **密钥交换阶段**
 - **阶段一交换 (Phase 1)：**
 - 建立一个安全的、经验证的信道（ISAKMP安全联盟）。
 - 主模式交换 (Main Mode)：提供身份保护机制，6条消息。（3个步骤为策略协商交换、密钥（DH和随机数）交换以及身份验证交换）
 - 野蛮模式交换 (Aggressive Mode)：3个步骤，3条消息，速度快，但身份未保护。头两条消息协商策略，交换Diffie Hellman公开值必需的辅助数据以及身份信息；第二条消息认证响应方；第三条消息认证发起方，并为发起方提供在场

的证据。



- **阶段二交换 (Phase 2):**

- 在阶段一建立的安全信道中，协商IPSec安全联盟（密钥材料和安全参数）。
- 快速模式交换 (Quick Mode)：3个步骤，3条消息，所有消息加密传输。

SSL (安全套接字层)

- **基本情况**

- Secure Socket Layer，1994年Netscape开发，用于保护Web通讯。
- 版本：1.0 (不成熟), 2.0 (解决Web安全), 3.0 (1996年发布), TLS 1.0 (1997年IETF发布, RFC 2246)。
- 设计目标：保密性、完整性（身份认证）、互操作性、可扩展性、相对效率。

- **协议体系**

- 底层：SSL记录协议 (SSL Record Protocol)。
- 上层：SSL握手协议、SSL密码变化协议、SSL警告协议。

- **SSL记录协议**

- 建立在可靠传输协议 (TCP) 之上。
- 提供连接安全性：保密性 (对称加密)、完整性 (HMAC)。
- 封装过程：Fragmentation (分片) -> Compression (无损压缩, 增加数据不超过1024B 可选) -> Add MAC (消息认证码) -> Encryption (加密) -> Append Header (添加头)。

- **SSL高层协议**

- **密码变化协议** (ContentType: 20)：只包含一条消息（一个字节1），用于切换状态，激活协商好的密码参数。它的作用是一个**信号**。它出现在握手协议的最后阶段。
- **警告协议** (ContentType: 21)：2字节，包含Level (Warning1/Fatal2) 和 Description。Fatal类型导致连接立即终止，会话ID失效。
- **握手协议** (ContentType: 22)：
 - 功能：客户和服务器相互认证、协商加密算法和密钥。
 - 提供连接安全性，有三个特点：
 - 身份认证（至少一方）
 - 协商得到的共享密钥是安全的
 - 协商过程可靠

- 流程：
 - (1) 交换Hello消息 (协商算法、随机值)。
 - (2) 交换密码参数 (Premaster secret)。
 - (3) 交换证书和密码信息 (身份认证)。
 - (4) 产生Master secret。
 - (5) 把安全参数提供给TLS记录层。
 - (6) 检验双方是否获得同样的安全参数。
- 重要概念
 - **SSL连接 (Connection)**: 点对点, 暂时的, 提供合适类型服务的传输。
 - **SSL会话 (Session)**: 客户与服务器间的关联, 由握手协议创建, 定义了一组可共享的加密安全参数, 避免昂贵的协商代价。

PGP

安全电子邮件系统 PGP (Pretty Good Privacy)

- 基本情况
 - PGP为电子邮件和文件存储应用提供了认证和保密性服务。
 - 特点/快速发展和流行的原因：
 - 选择理想的密码算法。
 - 把算法很好地集成到通用应用中, 独立于操作系统和微处理器。
 - 自由发放, 包括文档、源代码等。
 - 不受任何组织和政府控制。

PGP功能列表

- 数字签名
 - 采用算法: DSS/SHA或RSA/SHA。
 - 说明: 用SHA-1创建散列码, 用发送者的私钥和DSS或RSA加密消息摘要。
- 消息加密
 - 采用算法: CAST或IDEA或3DES、AES及RSA或D-F。
 - 说明: 消息用一次性会话密钥加密, 会话密钥用接收方的公钥加密。
- 压缩
 - 采用算法: ZIP。
 - 说明: 消息用ZIP算法压缩。
- 邮件兼容性
 - 采用算法: Radix 64。
 - 说明: 邮件应用完全透明, 加密后的消息用Radix 64转换。
- 数据分段
 - 说明: 为了适应邮件的大小限制, PGP支持分段和重组。

- 符号表
 - Ks：常规加密中的会话密钥
 - KRa：公开密钥系统中用户A的私有密钥
 - KUa：公开密钥系统中用户A的公开密钥
 - EP：公开密钥加密
 - DP：公开密钥解密
 - EC：常规加密
 - DC：常规解密
 - H：散列函数
 - ||：串接操作(并置)
 - Z：使用ZIP算法进行压缩
 - R64：基数为64的ASCII格式转换

PGP操作描述

- 数字签名与认证
 - 发送方：
 - 创建报文。
 - 使用SHA-1生成报文的160位散列码。
 - 使用发送者的私有密钥，用RSA算法对散列码加密(签名)，并置在报文前面。
 - 接收方：
 - 使用发送者的公开密钥，用RSA解密和恢复散列码。
 - 计算报文的散列码，与解密得到的进行比较，如果两者匹配，则报文通过鉴别。
 - 说明：
 - 签名也可以使用DSS/SHA-1来生成。
 - RSA的强度保证了发送方的身份。
 - SHA-1的强度保证了签名的有效性。
 - PGP也支持分离的数字签名（可用于对消息进行单独的日志记录；可执行程序的签名记录以检查病毒；文档多方签名避免嵌套签名）。
- 保密性
 - 发送方：
 - 生成消息M并为该消息生成一个128位随机数作为会话密钥。
 - 采用CAST-128(或IDEA或3DES)对报文M进行加密。
 - 采用RSA，使用接收者的公开密钥加密会话密钥，并置到报文前面。
 - 接收方：
 - 采用RSA，使用自己的私钥解密恢复会话密钥。
 - 使用会话密钥解密恢复报文M。
 - 说明：
 - 对称加密算法和公钥加密算法的结合可以缩短加密时间。

- 用公钥算法解决了会话密钥的单向分发问题（不需要专门的会话密钥交换协议；适合邮件系统的存储-转发特性）。
- 每个消息都有自己的一次性密钥，进一步增强了保密强度，每个密钥只加密很小部分的明文内容。
- 可以使用Diffie-Hellman算法生成会话密钥。
- **保密与认证的结合**
 - 两种服务都需要时，发送者先用自己的私钥签名，然后用会话密钥加密消息，再用接收者的公钥加密会话密钥。
 - 顺序：签名 ——> 压缩 ——> 加密。

密钥管理

- **PGP使用的密钥类型**
 - 一次性会话传统密钥。
 - 公钥。
 - 私钥。
 - 基于口令短语的传统密钥。
- **PGP对密钥的需求**
 - 会话密钥：需要一种生成不可预知的会话密钥的方法，PGP使用了一种复杂的随机密钥生成算法(一定的真随机性)。
 - 公钥和私钥：
 - 需要某种手段来标识具体的密钥；
 - 一个用户可能拥有多个公钥/私钥对；需要密钥更新管理。
- **密钥标识符 (KeyID)**
 - 问题：一个用户有多个公钥/私钥对时，接收者如何知道发送者是用哪个公钥来加密会话密钥的？
 - 解决方案：将公钥 和消息一起传送，定义KeyID，包括64个有效位（PGP采用公钥的低64位作为KeyID）。即用户ID和密钥ID标识一个密钥。
 - 作用：
 - 将一个标识符与一个公钥关联，对一个用户来说唯一。
 - 对于PGP数字签名，KeyID也很必需，用于指示用哪个公钥来验证签名。
 - PGP消息中包括两个KeyID，分别提供保密与认证功能。
- **钥匙环 (Key Rings)**
 - 需要一种系统化的方法存储和组织这些密钥以保证有效使用这些密钥。
 - 用户机器(节点)上有一对数据结构：
 - **私钥环**：存储本节点拥有的公钥/私钥对。
 - **公钥环**：存储本节点所知道的其他用户的公钥。
- **PGP私钥环**
 - 信息包含：时间戳、KeyID、公钥、私钥、UserID。
 - UserID：通常是用户的邮件地址，也可以是一个名字，可以重名。
 - **私钥如何保存：**

- 用户选择一个口令短语用于加密私钥。
- 当系统用RSA生成一个新的公钥/私钥对时，要求用户输入口令短语。对该短语使用SHA-1生成一个160位的散列码后，销毁该短语。
- 系统用其中128位作为密钥用CAST-128加密私钥，然后销毁这个散列码，并将加密后的私钥存储到私钥环中。
- 当用户要访问私钥环中的私钥时，必须提供口令短语。PGP将取出加密后的私钥，生成散列码，解密私钥。

邮件数据处理

- **处理顺序**
 - 签名 ——> 压缩 ——> 加密。
- **压缩的作用**
 - 对邮件传输或存储都有节省空间的好处。
- **签名后压缩的原因**
 - 不需要为检验签名而保留压缩版本的消息。
 - 不同压缩结果不同，但是解压结果相同都是明文，因此对明文签名才能正确验证。
 - 为了检验而再做压缩不能保证一致性，压缩算法的不同实现版本可能会产生不同的结果。
- **压缩之后再加密的原因**
 - 压缩后的消息其冗余小，消除统计规律性，增加密码分析的难度。
 - 压缩方法靠去除冗余（如重复的词）实现，加密后成了乱码无法有效压缩，甚至文件还会变大，即若先加密，则压缩难以见效。
- **E-mail兼容性**
 - PGP处理后的消息，部分或者全部是加密后的消息流，为任意的8位字节。
 - 某些邮件系统只允许ASCII字符，所以PGP提供了转换到ASCII格式的功能，采用了Radix-64转换方案。

PGP处理消息的过程

- **发送方处理消息的过程**
 - **签名：**
 - 从私钥环中得到私钥，利用userid作为索引。
 - PGP提示输入口令短语，恢复私钥。
 - 构造签名部分。
 - **加密：**
 - PGP产生一个会话密钥，并加密消息。
 - PGP用接收者userid从公钥环中获取其公钥。
 - 构造消息的会话密钥部分。
- **接收方处理消息的过程**
 - **解密消息：**

- PGP用消息的会话密钥部分中的KeyID作为索引，从私钥环中获取私钥。
- PGP提示输入口令短语，恢复私钥。
- PGP恢复会话密钥，并解密消息。
- **验证消息：**
 - PGP用消息的签名部分中的KeyID作为索引，从公钥环中获取发送者的公钥。
 - PGP恢复被传输过来的消息摘要。
 - PGP对于接收到的消息作摘要，并与上一步的结果作比较。